

Semi-Shield ISMS

系統細部架構文件

產出時間：2026-08-25 16:56 | 來源：ARCHITECTURE.md

Semi-Shield ISMS — 系統細部架構

產出日期：2026-08-25

版本：依目前 codebase 整理

1. 系統總覽

Semi-Shield ISMS 是 OT 工控資安合規平台，核心設計原則為「No Evidence, No Compliance Claim」（無證據、不宣稱合規）。

```
瀏覽器 (Port 2000)
platform.html | OT.html | agent_chat.html | compliance.html
↓ HTTP / REST
code/server/app.py (Flask)
路由 · OT 掃描 · Agent 邏輯 · LLM 編排 · 圖表後處理
↓
ollama_service | rag_service | guardrail + hallucination | evidence | compliance
↓
Ollama :11434 | RAG Index | DL 模型 (CPU) | data/*.jsonl | ot/*.txt
```

啟動鏈：app.py → code/server/app.py → Flask run_server()

預設後端：Ollama (LLM_BACKEND=ollama)，可切換本地 Transformers (GPU/Edge)

2. 分層架構

2.1 前端層 (web/)

頁面	路由	職責
platform.html	/、/platform	整合首頁：監控戰情 + AI 對話 iframe
OT.html	/monitor	監控戰情室：六控制項 KPI、事件串 流、地端診斷、PDF/TXT 匯出
agent_chat.html	/chat	AI 對話：多輪 history、模型切換、chart 渲染

頁面	路由	職責
compliance.html	/compliance	合規管線、控制項矩陣、Evidence、Review Queue

2.2 API 層 (code/server/app.py)

群組	主要端點
監控	GET /api/monitor/data
診斷	POST /api/audit/analyze、/api/audit/analyze_all
對話	POST /api/agent/chat
LLM	GET /api/llm/models、POST /api/llm/switch
合規	GET /api/compliance/*、POST /api/compliance/pipeline
證據	GET /api/evidence、GET /api/evidence/<id>
覆核	GET/POST /api/review/queue、POST /api/review/resolve
安全	GET /api/safety/status

2.3 服務層 (code/services/)

模組	職責
ollama_service.py	Ollama HTTP chat、模型列表/切換
rag_service.py	向量/關鍵字 RAG 檢索
guardrail_service.py	輸入護欄 (safe/unsafe DL + 平台 allowlist)
hallucination_guard_service.py	輸出幻覺偵測 (grounded/hallucinated · threshold=0.6)
compliance_service.py	Annex A 矩陣、覆蓋率 KPI、GRC 定位
evidence_service.py	Evidence 註冊、hash chain 追溯
review_queue.py	Human Review Queue
ai_reviewer_service.py	AI Reviewer 自動覆核
agent_orchestrator.py	四階段管線規格 (Collector→Auditor→Reviewer→Reporter)

2.4 資料層

路徑	內容
ot/*.txt	Cisco 設備 syslog 原始日誌

路徑	內容
compliance/*.json	控制項矩陣、KPI、evidence schema
data/evidence_registry.jsonl	Evidence 鏈
data/review_queue.jsonl	待覆核項目
train_ai/train_rag/	知識庫 + embedding 索引
train_ai/train_gur/	輸入護欄微調模型
train_ai/train_hallucination/	幻覺偵測微調模型
train_ai/train_llm/	OT 領域 LLM 微調權重
config/ollama_models.json	模型別名對照表

3. 核心資料流

3.1 監控戰情室資料流

```
ot/*.txt → scan_ot_directory()
→ metrics ( 六控制項 )
→ parsed_logs ( 事件串流 )
→ control_bundles
→ all_logs_content ( 設備摘要 )
→ get_ot_monitor_data ( 快取 )
→ _attach_evidence_and_reviews
→ GET /api/monitor/data → OT.html
```

六個自動化監控控制項：

control_key	Annex A	監控內容
sec_gem_log	A.8.24	SNMP/crypto 傳輸安全
recipe_audit	A.8.19	組態變更 / UPDOWN
access_control	A.5.15	AAA / LOGIN 事件
patch_management	A.8.8	Patch hints
supplier_security	A.5.19	CDP/LLDP 外部鄰居
malware_defense	A.8.7	惡意軟體命中

掃描結果以檔案 mtime/size 簽章快取，避免輪詢重掃大量日誌。

3.2 AI 對話管線 (POST /api/agent/chat)

```
使用者 message + history
→ 輸入護欄 guardrail_service
```

```

→ RAG retrieve_rag_for_query (force=True)
→ build_monitor_warroom_context
→ ask_agent → run_llm
→ sanitize_agent_chat_reply
→ 幻覺護欄 hallucination_guard
→ ensure_visual_reply (圖表)
→ 輸出脫敏 → JSON reply

```

Prompt 組成 (ask_agent) :

1. System : 繁體中文規則 + 防幻覺鐵律 + (有日誌時) 日誌優先鐵律
2. History (日誌模式) : 僅保留最多 2 則使用者追問 , 不帶 assistant 舊回答
3. User 本則 : 監控戰情室上下文 + RAG + 合規底稿 + 使用者問題

重要設計 :

- 所有非寒暄問題一律 RAG 檢索
- 微調模型一律注入 build_monitor_warroom_context() (與 OT.html 同源)
- 日誌優先 : 有監控資料時 , 事實以日誌為準
- 回答一律走 LLM , 不做 grounded 直答捷徑

3.3 合規四階段管線

```

Collector → Auditor → Reviewer → Reporter
scan_ot RAG+LLM 護欄+Queue PDF/TXT
evidence 診斷 邊界覆核 報告匯出

```

由 POST /api/compliance/pipeline 觸發。

4. AI / ML 子系統

4.1 LLM 後端

模式	觸發	說明
Ollama (預設)	LLM_BACKEND=ollama	HTTP → 127.0.0.1:11434
Transformers	本地 GPU	4-bit 量化
Edge / CPU	run_edge.bat	LLM_SPEED=edge/cpu_fast

速度檔 (LLM_SPEED) : turbo | fast | balanced | edge | cpu_fast

微調 vs 基底 : _llm_allows_knowledge_graph() 決定是否啟用 RAG / 監控注入。

4.2 雙層 DL 護欄

層	模型路徑	時機	閾值
輸入	train_ai/train_gur/fine_tuned_guardrail/	問題進 LLM 前	0.5
輸出	train_ai/train_hallucination/fine_tuned_hallucination_guard/	回覆後	0.6

4.3 RAG

- 知識庫：train_ai/train_rag/knowledge_base.json
- 索引：train_ai/train_rag/index/
- 開關：OT_ENABLE_RAG=1

5. 監控戰情上下文 (AI 對話用)

build_monitor_warroom_context() 匯總：

- 資料來源摘要 (目錄、檔案數、設備 ID)
- 六控制項 KPI + evidence_id
- 合規覆蓋率 (Annex A matrix)
- 各控制項 bundle (日誌樣本 + metric_summary)
- 設備/檔案明細 (事件量、控制項分布)
- 近期稽核事件串流 (最多 48 筆)

上限 WARROOM_CTX_LIMIT (turbo 預設 4800 字)，可設 OT_WARROOM_CTX_LIMIT。

6. 環境變數速查

變數	預設	用途
PORT	2000	Web 埠
LLM_BACKEND	ollama	LLM 後端
OLLAMA_MODEL	qwen2.5:3b	預設模型
OT_ENABLE_RAG	1	RAG 開關
ENABLE_GUARDRAIL	1	輸入護欄
ENABLE_HALLUCINATION_GUARD	1	輸出幻覺偵測
LLM_SPEED	turbo/edge	速度檔
OT_WARROOM_CTX_LIMIT	依速度檔	戰情上下文字數上限

變數	預設	用途
CHAT_LOG_HISTORY_USER_TURNS	2	日誌模式保留的使用者追問數
OT_SITE_CODE	ot-fab	Evidence ID 站點碼

7. 目錄樹 (精簡)

```
ot_test/
├─ app.py
├─ code/server/app.py
├─ code/services/
├─ web/
├─ ot/
├─ compliance/
├─ data/
├─ config/
├─ train_ai/
├─ scripts/
└─ docs/
```

8. 架構特徵摘要

面向	現況
部署	單機 Flask + Ollama · 同程序呼叫
通訊	無 message bus · Python function call
事實來源	OT 日誌掃描 → 監控戰情 → AI 對話注入
安全	輸入護欄 + 輸出幻覺偵測 + Human Review
多輪對話	日誌優先：只留使用者追問
Phase 2	LangGraph/CrewAI 編排 (agent_orchestrator.py)